

Compliance & Data-Handling Overview

Prepared for the 299Trust compliance team to support compliance / SEC review. Plain-English summary of what the app is, what data it handles, how it's secured, and what it deliberately does not do. This document is informational and is not legal advice; compliance determinations rest with 299Trust.

Status: Development is **paused pending compliance review**. Nothing is live to customers. The developer remains available to answer questions, make any changes compliance requires, or keep specific features disabled.

1. What the app is

A mobile app (iOS/Android) that wraps the **existing** 299Trust DIY revocable living-trust process in a guided, trustworthy interface. It does **not** change that process. The current Formstack questionnaire, Stripe payment, and document generation remain the system of record. The app adds: onboarding/education, plan selection, a guided path into the existing questionnaire, status messaging, and business analytics.

Purpose: increase customer confidence in, and completion of, the existing self-service flow.

2. What it deliberately does NOT do

- **Does not** generate, render, or store any legal/estate documents (trusts, wills, powers of attorney). Document generation stays entirely in Formstack.
- **Does not** process payments itself — payment runs through the existing Formstack/Stripe integration, unchanged.
- **Does not** provide legal, tax, or investment advice. It is self-help document-preparation support only.
- **Does not** replace the Formstack workflow — Formstack remains the source of truth.

3. Data the app collects

Category	Examples	Notes
Anonymous device/session	install id, platform, app version, funnel steps	analytics; no PII required
Lead contact	name, email, optional phone, plan interest	optional, customer-provided
Submission mirror	Formstack submission id, plan, payment status, amount, timestamp	pointer + status — not documents
Webhook payload (audit)	raw JSON Formstack sends on submit	may contain submitted field values; retention can be reduced or disabled
AI intake (<i>only if enabled</i>)	chat transcript, mapped answers (may include beneficiaries/assets)	OFF by default — see §6

4. Where data is stored & how it's secured

- **Location:** Supabase (managed PostgreSQL) on AWS, **US region (Oregon)**.
- **Encryption:** TLS in transit; encryption at rest (AWS/Supabase default).
- **Access control:** Row-Level Security is **default-deny on every table**. The public app key has no direct database access; all reads/writes go through controlled server-side functions. Secrets/API keys are stored server-side (write-only) and never shipped in the app.
- **Admin dashboard:** internal analytics view, access-restricted by a shared secret today; slated to move to authenticated, role-based login.

5. Data flow (high level)

Customer uses app > app opens the **existing** Formstack questionnaire (tagged with a session id) > customer completes and pays **in Formstack** (unchanged) > Formstack notifies our backend via webhook > backend records completion/payment **status** for analytics. The app is a guided shell + analytics layer around the existing, unchanged Formstack process.

6. AI-guided intake (optional, OFF by default)

A future, optional feature allowing customers to answer conversationally, with answers mapped into the existing Formstack fields. Compliance-relevant controls already built in:

- **Disabled by default** (feature-flagged off).
- The assistant is instructed **not** to give legal/tax advice and to defer to an attorney.
- **Human-in-the-loop**: sensitive answers (beneficiaries, trustees, guardians) require explicit customer confirmation before use; the assistant never finalizes them on its own.
- **No auto-submit** — Formstack remains the source of truth.
- Conversation transcripts are retained (supports recordkeeping) and can be disabled or retention-limited.
- Vendor: Anthropic (processes conversation text only when the feature is on).

This is the most likely focus of review and **can remain disabled** pending compliance sign-off without affecting the rest of the app.

7. Recordkeeping & audit

- An **append-only audit log** records submission/webhook events and administrative access, with timestamps.
- Submission status history is retained.
- These support SEC-style recordkeeping/retention expectations; retention schedules can be configured to 299Trust's policy.

8. Third-party vendors (sub-processors)

Vendor	Role	Handles customer PII?
Formstack	Questionnaire, payment (via Stripe), document generation — existing	Yes (system of record)
Stripe	Payment processing within Formstack — existing	Yes (payment)
Supabase (AWS, US)	App database + serverless functions	Yes (contact, analytics, mirror)
Anthropic	AI intake — only if enabled	Conversation content, when enabled
Netlify	Hosts internal admin dashboard (static; no customer PII in bundle)	No
Apple / Google / Expo	App distribution	No

9. For compliance to confirm / decide

- Whether to enable the AI-guided intake at all (currently off).
- Data **retention & deletion** schedule (and whether to minimize raw webhook payload storage).
- **Privacy policy + terms of use** (to be finalized before public launch).
- Applicability of **Reg S-P** (privacy/safeguards) and applicable recordkeeping rules (e.g., IA Rule 204-2 / Rule 17a-4) to this customer-facing tool and its communications.
- Required in-app **disclosures/disclaimers** (a “self-help, not legal advice” disclaimer is already shown on the welcome screen).

- Admin dashboard **access policy** (move to authenticated, role-based access).

Prepared by Gautam Dogra · June 2026 · Questions: gdogra@gmail.com